Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.5 / COMPANION WORKBOOK

Addressing and tiered administration

DHCP, admin seats & where privilege may sign in

Build the control plane before the fleet: DHCP with its core relay for the workstation VLAN, three dedicated administration systems in VLAN 60, and directory-enforced tier restrictions proven by both successful in-tier sessions and logged out-of-tier denials.

MATERIALS EDITION 1.4 / COURSE 1.5

Updated 9 October 2026 · sbd-tiered-admin

NAME _____ / DATE _____

© 2026 Secure By Design Team LLC.

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Design the tiers and the address plan

02 Build SBD-DHCP01 and the relay

03 Build the administration systems

04 Restrict where privilege can sign in

05 Prove the tiers and the addressing

06 Delta scan and hand off

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

Before you start

This course builds the control plane before the fleet exists: DHCP for the workstation VLAN, and a tiered administration model where privileged sessions only ever start from dedicated hosts. The model's rule is strict — the jump systems administer; they browse nothing, read no mail, and accept no inbound sessions from user space.

Prerequisites

- ☐ Complete course 1.4: the finished two-tier PKI with its publication site and templates, plus course 1.3's OU structure with the Admin OU in place. The network's routing and default-deny segmentation, with its access control list (ACL) register, are already in place.
- ☐ Provision Windows Server hosts for SBD-DHCP01 (10.0.20.10) and the three administration systems in VLAN 60: AdminJumpBox01 (.10), SBD-ADMIN-SRV01 (.20), SBD-ADMIN-PC01 (.30).
- ☐ Decide the privileged accounts: separate admin identities per tier, never daily-driver accounts with admin rights.

What this course builds

- Serve the workstation VLAN through an authorized DHCP server and core relay.
- Stand up single-purpose administration hosts for each tier in the Admin OU.
- Enforce and prove per-tier sign-in restrictions with captured denial evidence.

Systems in scope

RECORD	YOUR OBSERVATION
SBD-DHCP01 — name, address, OS build	
AdminJumpBox01 — name, address, OS build	
SBD-ADMIN-SRV01 — name, address, OS build	
SBD-ADMIN-PC01 — name, address, OS build	

© 2026 Secure By Design Team LLC.

LESSON 01 / ABOUT 20 MIN

Design the tiers and the address plan

> **WHY THIS MATTERS** Tiering is one sentence with teeth: credentials that control a tier never touch a less-trusted one. Write that policy against the OU structure, then plan the DHCP scope the fleet will live in — both before any host is built.

In this lesson you will

- Define the tiers and map each to systems, OUs, and admin accounts.
- Write the credential rule each tier enforces.
- Plan the VLAN 80 DHCP scope, options, and relay.

Follow the build

1. Define three tiers against what exists, using Microsoft's rule: anything that can control a Tier 0 system is Tier 0. Tier 0 is the identity and trust fabric (DCs, both CAs, PKI-MGMT01) plus what controls it — the hypervisor hosts and their console, the core router's management, and the DC-facing parts of the tools that patch, protect, scan, monitor, and back up the DCs. Tier 1 is the member servers; Tier 2 the user endpoints. Map each tier to its OUs: Tier 0 to the Domain Controllers OU plus a new Tier 0 Servers OU for SBD-SUBCA01 and SBD-PKI-MGMT01 (lesson 4 moves them out of the Servers OU), Tier 1 to the Servers OU, and Tier 2 to the Workstations OU.
2. Write the credential rule per tier: a Tier 0 account signs in only on Tier 0 systems and AdminJumpBox01; Tier 1 admins work from SBD-ADMIN-SRV01; Tier 2 from SBD-ADMIN-PC01. The audit custodian uses separate accounts and sessions on SBD-ADMIN-SRV01 that ordinary server operators cannot use. Each administrator gets separate per-tier accounts — the daily account holds no admin rights anywhere.
3. Plan the DHCP design: scope 10.0.80.100–199 for the workstation VLAN — 100 addresses, room for the 50 PCs, the test clients, and replacement machines whose old leases have not yet expired — with options for router 10.0.80.1, the two DCs as DNS, and the sbd.test domain; the core router relays VLAN 80 broadcasts to SBD-DHCP01; everything else stays static.
4. Add the register rows this course needs: VLAN 60 to each tier's management ports (rules A01–A04 in Inside the Network), DHCP relay from the core to SBD-DHCP01 (F04), and explicit denies from VLAN 80 into VLAN 60 — user space never initiates toward the admin plane.

Check your result

```
# Capture the design inputs: OU targets and current account separation.
Get-ADOrganizationalUnit -Filter * | Select-Object Name, DistinguishedName
Get-ADGroupMember 'Domain Admins' | Select-Object Name, SamAccountName
```

> **WHAT SUCCESS LOOKS LIKE** The tier map names systems, OUs, admin hosts, and accounts for every tier; the DHCP plan is written; and the register has the new permit and deny rows with owners.

Your record

Evidence to keep: Keep the tier access matrix, the per-administrator account plan, the DHCP scope design, and the updated register rows.

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What is the one-sentence tiering rule?

REMEMBER Three tiers, each with its systems, OU, admin host, and accounts. The credential rule is written before any host enforces it. DHCP scope, options, relay, and register rows are planned.

Microsoft · Dynamic Host Configuration Protocol (DHCP)

Microsoft · Privileged access workstations and the access model

NIST · SP 800-53 Rev. 5 security controls

LESSON 02 / ABOUT 25 MIN

Build SBD-DHCP01 and the relay

> **WHY THIS MATTERS** Addressing is the first service fifty machines will ask for. Build the DHCP server, authorize it in the directory so rogue servers stand out, and relay VLAN 80's broadcasts through the core.

In this lesson you will

- Install and authorize the DHCP role on SBD-DHCP01.
- Create the VLAN 80 scope with the planned options.
- Configure the core relay and prove a lease end to end.

Follow the build

1. Install the DHCP role on SBD-DHCP01 in the Servers OU and complete directory authorization — an unauthorized Windows DHCP server refuses to serve domain networks, the directory's built-in check against rogue DHCP servers.
2. Create the IPv4 scope 10.0.80.100–199 with the planned options: router 10.0.80.1, DNS 10.0.10.10 and 10.0.10.11, domain sbd.test. Leave every other VLAN static as designed.
3. Configure dynamic DNS updates using a dedicated low-privilege credential so client records register securely in the sbd.test zone from course 1.2.
4. Enable the DHCP relay on the core router's VLAN 80 interface toward 10.0.20.10, confirm the register row (F04) permits it, then pull a lease with a temporary test VM in VLAN 80 and watch its A record appear.

Check your result

```
Get-DhcpServerInDC
Get-DhcpServerv4Scope | Select-Object ScopeId, StartRange, EndRange, State
Get-DhcpServerv4OptionValue -ScopeId 10.0.80.0 | Select-Object OptionId, Value
Resolve-DnsName sbd-test80.sbd.test
```

> **WHAT SUCCESS LOOKS LIKE** The server shows as authorized, the scope serves the planned range and options through the relay, and the test client's secure dynamic DNS record exists on both DCs.

Your record

Evidence to keep: Record the authorization output, scope and option configuration, the relay setting on the core, and the test lease with its DNS registration.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

What does directory authorization of a DHCP server give you?

REMEMBER SBD-DHCP01 is authorized, scoped, and serving through the relay. Options hand out the gateway, both DCs, and the domain. A test lease proved addressing and secure DNS registration together.

Microsoft · Dynamic Host Configuration Protocol (DHCP)

Microsoft · Configure a firewall for Active Directory domains

LESSON 03 / ABOUT 35 MIN

Build the administration systems

WHY THIS MATTERS Privileged work gets dedicated, hardened seats: one jump host for Tier 0, one workstation for server administration, one for endpoint administration — each in the Admin OU, each doing nothing else.

In this lesson you will

- Link the hardening policies to the Admin OU's computer sub-OUs, then build the three VLAN 60 systems into them.
- Keep them single-purpose: hardened, minimal, no user-space services.
- Register and restrict their management paths.

Follow the build

1. Create two computer sub-OUs under the Admin OU — Admin Servers for AdminJumpBox01 and SBD-ADMIN-SRV01, Admin Workstations for SBD-ADMIN-PC01 — and link course 1.3's Security Technical Implementation Guide (STIG) Group Policy objects (GPOs) to them before any seat joins: the member-server policies to Admin Servers and the Windows client policies from the same package to Admin Workstations. Course 1.3 linked them only to the Domain Controllers and Servers OUs, so without this step the seats would boot unhardened.
2. Build AdminJumpBox01, SBD-ADMIN-SRV01, and SBD-ADMIN-PC01 as clean Windows Server (or Windows client, for the endpoint seat) installs and join each into its sub-OU, so the hardening applies from first boot.
3. Strip them to purpose: no browsing to anything but internal admin interfaces, no mail, no file shares hosted, and the management tools for exactly their tier — Remote Server Administration Tools (RSAT) on the server seats, endpoint tooling on the PC seat.
4. Register the management paths: VLAN 60 to Tier 0 and Tier 1 ports (remote desktop 3389, remote management 5985–5986, AD Web Services 9389 to the domain controllers, SSH 22 for the domain-joined Linux servers) from the specific admin host each tier allows, and the router's management on VLAN 100 from AdminJumpBox01 only. Keep the VLAN 80 → VLAN 60 deny from lesson 1 in force.
5. Require the admin hosts' own local firewalls to accept management inbound from nowhere — sessions originate here, they never terminate here. On both domain controllers, scope the existing Remote Desktop, Windows Remote Management, and Active Directory Web Services firewall rules to AdminJumpBox01 and VLAN 10: allow rules add up, so a new, narrower rule would not restrict the broad ones already enabled.

Check your result

```
Get-ADComputer -SearchBase 'OU=Admin,OU=SBD,DC=sbd,DC=test' -Filter * | Select-Object
Name, DistinguishedName
Get-GPInheritance -Target 'OU=Admin Servers,OU=Admin,OU=SBD,DC=sbd,DC=test'
Get-GPInheritance -Target 'OU=Admin Workstations,OU=Admin,OU=SBD,DC=sbd,DC=test'
Test-NetConnection SBD-DC01.sbd.test -Port 5985
gpresult /r /scope:computer
```

WHAT SUCCESS LOOKS LIKE All three hosts sit in their Admin sub-OUs with the STIG GPOs linked there and applied, management ports answer from the correct admin host per tier, and nothing in user space can open a session toward VLAN 60.

© 2026 Secure By Design Team LLC.

Your record

Evidence to keep: Record each host's build sheet, OU placement, the sub-OU GPO links, gpresult output, and the register rows for its permitted management paths.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why do the admin hosts run nothing but administration?

REMEMBER Three single-purpose admin seats, hardened from first boot. Management flows outward only; VLAN 60 accepts nothing inbound. Every management path is a register row.

Microsoft · Privileged access workstations and the access model

Microsoft · Configure a firewall for Active Directory domains

LESSON 04 / ABOUT 40 MIN

Restrict where privilege can sign in

> **WHY THIS MATTERS** The tier rule becomes real when the directory refuses the wrong sign-in. Give Tier 0 servers their own OU first, deny privileged logons on lower tiers by policy, protect the highest accounts, and make the refusal something you can show in a log.

In this lesson you will

- Move the Tier 0 member servers into their own OU before any deny policy lands.
- Enforce per-tier sign-in restrictions with Group Policy logon rights, and record the one network-logon exception.
- Protect Tier 0 accounts and prove a cross-tier sign-in is denied and logged.

Follow the build

1. Create the Tier 0 Servers OU (OU=Tier 0 Servers,OU=SBD,DC=sbd,DC=test) with deletion protection, link course 1.3's member-server STIG GPOs to it so nothing loses its hardening, and move SBD-SUBCA01 and SBD-PKI-MGMT01 there. Both are Tier 0, and the Servers OU is about to deny Tier 0 sign-ins — left there, they would lock Tier 0 out of its own systems.
2. Create one tier logon GPO for the Servers OU — now Tier 1 only — and one for the Workstations OU, and never link either to the Domain Controllers or Tier 0 Servers OUs. User rights don't merge across GPOs: for each right, the highest-precedence GPO that sets it wins, so each list repeats the entries course 1.3's STIG GPO sets for that right (such as Domain Admins and Enterprise Admins), and the tier GPO links above the STIG GPO. On the Servers OU, give the Tier 0 admin group (SBD Tier 0 Admins in this sample) Deny log on locally, Deny log on through Remote Desktop Services, Deny log on as a batch job, and Deny log on as a service. On the Workstations OU, give both the Tier 0 and Tier 1 groups those four denies plus Deny access to this computer from the network.
3. On the Servers OU, set Deny access to this computer from the network — the Tier 0 group plus the STIG's entries — in a separate GPO that excludes the SBD Tier 0 Console Hosts group through security filtering (deny Apply group policy). Course 1.8 adds SBD-WSUS01 and SBD-EPO01 to that group, so those two keep only the STIG's own setting. From AdminJumpBox01, Tier 0 manages the domain controllers' WSUS update ring and their agent policy in Trellix ePolicy Orchestrator (ePO) through those two consoles, using Tier 0 task accounts outside Domain Admins and Enterprise Admins (which the STIG denies network logon on member servers); a Kerberos network logon leaves no reusable credentials on the server. Record the exception — the two servers, the accounts, the reason, and its owner — in the course 1.3 exception record.
4. Add Tier 0 administrators to the Protected Users group so the domain refuses their weaker authentication paths, and note the behavior of the newest Windows Server release that supports this design: RC4 ticket-granting tickets are gone and legacy remote password changes are blocked for protected accounts. Protected Users accounts also cannot be delegated, which keeps the console exception free of reusable credentials.
5. Keep the built-in safety valves: one documented break-glass account, excluded from the deny policies, with its password sealed and its every use alarmed in a later logging course.

6. Record the multifactor decision the model calls for on VLAN 60 — smart card or certificate-based sign-in for privileged accounts is the natural follow-on to course 1.4's templates; write the decision and its target date even if implementation waits.

Check your result

```
Get-ADComputer -SearchBase 'OU=Tier 0 Servers,OU=SBD,DC=sbd,DC=test' -Filter * | Select-
Object Name
Get-ADGroupMember 'Protected Users' | Select-Object Name
# On the Tier 2 test machine: export the effective logon rights and read the deny lines.
secedit /export /mergedpolicy /cfg C:\Evidence\tiered-admin\user-rights.inf /areas
user_rights
Select-String -Path C:\Evidence\tiered-admin\user-rights.inf -Pattern 'SeDeny'
(Get-ADGroup 'SBD Tier 0 Admins').SID.Value   # from an admin seat: this SID must appear
on those lines
# After the refused Tier 0 sign-in: event 4625 with status 0xC000015B (logon type not
granted).
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625; StartTime=(Get-
Date).AddHours(-1)} | Where-Object Message -match '0xC000015B' | Select-Object
TimeCreated, Id
```

WHAT SUCCESS LOOKS LIKE SBD-SUBCA01 and SBD-PKI-MGMT01 sit in the Tier 0 Servers OU and still accept Tier 0 sign-ins; on a Tier 2 test machine the deny rights list the Tier 0 group's SID, and a Tier 0 sign-in there is refused with Security event 4625 (status 0xC000015B); the console network-logon exception is in the exception record; Protected Users contains the Tier 0 admins; and the break-glass and MFA decisions are written.

Your record

Evidence to keep: Keep the Tier 0 Servers OU move, the logon-rights GPO reports with their links and security filtering, the user-rights export, the refused sign-in's 4625 event, the exception record entry, the Protected Users membership, and the break-glass and MFA decision records.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What turns the tier rule from policy into enforcement?

> **REMEMBER** Tier 0 servers have their own OU, so the deny policies never lock Tier 0 out. Lower tiers refuse higher-tier credentials by policy, with events to prove it; the console network-logon exception is recorded. Tier 0 accounts sit in Protected Users, backed by the stricter defaults of the newest Windows Server release. Break-glass and MFA are written decisions, not loose ends.

Microsoft · Privileged access workstations and the access model

Microsoft · User Rights Assignment

Microsoft · Administrative tools and logon types

Microsoft · Protected Users security group

Microsoft · secedit /export

Microsoft · 4625(F): An account failed to log on

Microsoft · What's new in Windows Server 2025

LESSON 05 / ABOUT 25 MIN

Prove the tiers and the addressing

WHY THIS MATTERS Run the matrix: every tier's administration works from its seat, every cross-tier attempt fails with an event, and the addressing service behaves exactly as registered.

In this lesson you will

- Verify each tier's management path from its designated seat.
- Capture the denial evidence for out-of-tier attempts.
- Re-prove DHCP, relay, and dynamic DNS under the finished rules.

Follow the build

1. From AdminJumpBox01, manage a DC and SBD-SUBCA01 with a Tier 0 account — the Tier 0 Servers OU kept that access; from SBD-ADMIN-SRV01, manage SBD-DHCP01 with a Tier 1 account; from SBD-ADMIN-PC01, manage the VLAN 80 test client with a Tier 2 account. Record each success with its session details, including the target's Security event 4624 (and 4672, which marks a logon that received special privileges).
2. Attempt the forbidden combinations — Tier 0 credentials at the test client, a session from VLAN 80 toward VLAN 60 — and capture both the refusal the user sees and the record the infrastructure writes: Security event 4625 with status 0xC000015B on the test client for the refused sign-in, and the router's deny-log entry for the VLAN 80 session.
3. Renew the test client's lease and confirm options, registration, and the relay still behave with all restrictions active; the control plane must not have broken the service plane.
4. Reconcile the tier access matrix against what you just proved and file it with the register — the two documents together are the admin plane's assessable record.

Check your result

```
Enter-PSSession SBD-DHCP01.sbd.test   # from SBD-ADMIN-SRV01, Tier 1 account
ipconfig /renew   # on the VLAN 80 test client
# On the test client: refused sign-ins in the last hour (status 0xC000015B = logon type
not granted).
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625; StartTime=(Get-
Date).AddHours(-1)} | Where-Object Message -match '0xC000015B' | Select-Object
TimeCreated, Id
```

WHAT SUCCESS LOOKS LIKE Every in-tier path succeeds, every tested out-of-tier path fails with captured evidence, and DHCP with dynamic DNS still works end to end under the full rule set.

Your record

Evidence to keep: Keep the completed tier matrix with timestamps, the denial captures, and the post-restriction lease and registration proof.

RECORD	YOUR OBSERVATION
Host(s) and time collected	

RECORD	YOUR OBSERVATION
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What pairs make the denial evidence complete?

> **REMEMBER** In-tier works, out-of-tier fails, and both are on record. Addressing and registration survived the restrictions. Matrix and register reconcile as one assessable story.

Microsoft · Privileged access workstations and the access model

Microsoft · 4625(F): An account failed to log on

Microsoft · Get-WinEvent

Microsoft · Configure a firewall for Active Directory domains

LESSON 06 / ABOUT 20 MIN

Delta scan and hand off

> **WHY THIS MATTERS** Four new systems joined and the directory's logon policy changed — the cadence fires again. Baseline the newcomers, rescan what changed, and hand the next course a network that can finally be watched from somewhere safe.

In this lesson you will

- Baseline the four new hosts and rescan the changed ones.
- Fold the course's decisions into the standing records.
- Write the handoff course 1.6 builds on.

Follow the build

1. Run first baselines on SBD-DHCP01 and the three admin hosts with the standard benchmark and tool versions, and rescan SBD-SUBCA01 and SBD-PKI-MGMT01 — the move to the Tier 0 Servers OU is their change, and the rescan should show their hardening intact.
2. Add this course's rows to the living records: the deny-logon and Protected Users decisions into the exception record where they interact with STIG values, beside lesson 4's console network-logon exception, and the new permit and deny rows into the register with owners.
3. Confirm the admin hosts appear in the hardening course's quarterly cadence; privileged seats are rescanned first from now on, not last.
4. Write the handoff: administration now has a home, which means the logging course can require that SIEM consoles and collectors are managed only from VLAN 60 — with the DC-facing scopes from the Tier 0 seat and audit retention under the custodian's separate accounts — say so explicitly for course 1.6.

Check your result

```
Get-ChildItem C:\Evidence\tiered-admin -Recurse | Select-Object Name, LastWriteTime
Get-FileHash -Algorithm SHA256 C:\Evidence\tiered-admin\*
```

> **WHAT SUCCESS LOOKS LIKE** Four baselines and the Tier 0 server rescans are filed with attributed deltas, the exception record and register carry the new rows, and the handoff names the logging course's management constraint.

Your record

Evidence to keep: Finish the checklist: scan set, updated records, the tier matrix, and the handoff note.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

Which systems are rescanned, not baselined, this time?

REMEMBER Baselines, rescans, and attributed deltas are on file. Exception record and register absorbed the course's decisions. Course 1.6 inherits a managed, addressable network.

NIST · SP 800-53 Rev. 5 security controls

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Design the tiers and the address plan	☐ yes	
02 Build SBD-DHCP01 and the relay	☐ yes	
03 Build the administration systems	☐ yes	
04 Restrict where privilege can sign in	☐ yes	
05 Prove the tiers and the addressing	☐ yes	
06 Delta scan and hand off	☐ yes	

Open items carried forward

Next in the learning path

That completes course 1.5. Course 1.6 builds the logging pipeline — collect, protect, analyze — before the fleet arrives to be watched.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.